

Maria Luiza Kodama RA: 823128136

Caio Coelho Jatoba RA: 823160685

Pesquisar, elaborar, entregar e apresentar (em grupo):

❑ Atividade 2:

Estudo: Comparativo de Certificações em Segurança da Informação;

Objetivo: O grupo deve escolher duas certificações de segurança da informação (por exemplo, ISO/IEC 27001 e PCI DSS) e fazer um estudo comparativo; Deve ser abordado:

- Requisitos para certificação;
- Setores de atuação (em que tipo de empresas ou indústrias cada certificação é mais usada);
- Benefícios de obter cada certificação;
- Diferenças na abordagem de gestão de riscos.

Entrega: Relatório comparativo e um infográfico que destaque as diferenças e similaridades.

1. Requisitos para Certificação

- ISO/IEC 27701
 - Precisa implementar (ou já ter) a ISO/IEC 27001, que trata da segurança da informação.
 - Há cursos específicos (Foundation, Implementer, Auditor) oferecidos por empresas como a PECB, BSI e outras.
 - É recomendável já ter noções sobre leis de proteção de dados, como a LGPD ou GDPR.
 - Para se certificar, normalmente é necessário fazer um exame ao final do curso.
- NIST CSF
 - Não tem pré-requisitos formais. Qualquer profissional pode estudar e aplicar os conceitos.
 - Existem cursos de capacitação, mas não há uma certificação "oficial" única do NIST — várias instituições oferecem treinamentos reconhecidos.
 - É indicado para quem trabalha com segurança da informação e quer uma abordagem mais prática e estratégica.

2. Onde cada uma é mais usada

- ISO/IEC 27701
 - Muito usada por empresas que lidam com dados pessoais: hospitais, bancos, e-commerces, escolas, startups de tecnologia, e setor público.
 - Ganha destaque em organizações que precisam mostrar conformidade com leis como a LGPD e o GDPR.
- NIST CSF
 - Bastante adotado nos EUA, mas também em empresas globais e multinacionais.
 - É comum em indústrias críticas, como energia, telecomunicações, transporte e finanças.
 - Também é referência no setor público e em organizações que buscam um modelo de maturidade em cibersegurança.

3. Benefícios de cada uma

- ISO/IEC 27701
 - Ajuda a mostrar que a empresa trata dados pessoais com seriedade.
 - Melhora a confiança dos clientes e parceiros.
 - Facilita a adequação à LGPD e GDPR.
 - Pode ser integrada com a ISO/IEC 27001, otimizando processos.
- NIST CSF
 - Estrutura clara para montar (ou melhorar) um programa de segurança da informação.
 - Permite alinhar a segurança com os objetivos do negócio.
 - Ajuda a identificar falhas e priorizar investimentos em segurança.
 - Adapta-se a empresas de qualquer porte e setor.

4. Diferenças na abordagem de gestão de riscos.

- ISO/IEC 27701
 - A gestão de riscos é voltada para privacidade — ou seja, os riscos relacionados ao uso, armazenamento e proteção de dados pessoais. Avalia impactos que o vazamento ou uso indevido desses dados pode causar.
 - É ideal para empresas que precisam garantir a privacidade como uma exigência legal.
- NIST CSF
 - Trabalha a gestão de riscos cibernéticos de forma bem ampla: inclui ameaças a sistemas, redes, pessoas e processos.
 - Divide a gestão em cinco grandes funções: Identificar, Proteger, Detectar, Responder e Recuperar.
 - Foca muito na continuidade dos negócios e na resiliência organizacional.

Infográfico: ISO/IEC 27701 vs NIST CSF

ISO/IEC 27701

NIST Cybersecurity Framework (CSF)

Foco: Privacidade de dados pessoais (PII)

Foco: Segurança cibernética e continuidade

Pré-requisito: ISO/IEC 27001

Pré-requisito: Nenhum formal

Usado em: Saúde, Finanças, E-commerce

Usado em: Energia, Indústrias críticas, Governo

Base legal: LGPD, GDPR

Base técnica: NIST SP 800-53, COBIT

Benefício: Adequação à lei e confiança

Benefício: Maturidade e resiliência cibernética

Gestão de risco: Avaliação de impactos à privacidade

Gestão de risco: Identificação, prevenção e resposta

Integração: ISO 27001, ISO 29100

Integração: COBIT, ISO 27001, NIST 800-53